

1. OBJETIVO DEL PENTEST

Define 3 objetivos concretos que tendría la evaluación de seguridad de Aurora Market.

1. IDENTIFICAR FUGA DE DATOS (IDOR)

Identificar la causa raíz del incidente de privacidad reportado por el usuario y evaluar vulnerabilidades de control de acceso (como IDOR) en la consulta de pedidos y perfiles.

2. EVALUACIÓN GENERAL DE SEGURIDAD WEB

Auditar la plataforma de e-commerce y el panel administrativo para detectar vulnerabilidades OWASP Top 10 (Inyecciones, Fallas de Autenticación, XSS y Desconfiguraciones).

3. REMEDIACIÓN Y FORTALECIMIENTO

Proporcionar un informe técnico con recomendaciones priorizadas de mitigación para fortalecer la postura de seguridad y proteger la información de los clientes.



TIP

Piensa en qué quieres lograr con el pentest y cómo ayudarán estos objetivos a Aurora Market.

2. ALCANCE

Identifica claramente qué se evaluará y qué queda fuera del alcance.

✓ SÍ SE EVALUARÁ (ELEMENTOS INCLUIDOS)

- **Aplicación Web Principal:** Registro, inicio de sesión, catálogo de productos, carrito de compras y estado de pedidos.
- **Panel Administrativo:** Módulos para gestión de productos, perfiles de usuarios y administración de pedidos.
- **APIs y Endpoints HTTP/HTTPS:** Todos los servicios web expuestos que interactúan con la base de datos de usuarios.

× FUERA DEL ALCANCE (ELEMENTOS EXCLUIDOS)

- Redes sociales oficiales de la empresa.
- Equipos personales, correos y dispositivos de los empleados.
- Sistemas y proveedores externos (pago, hosting de terceros).
- Ataques de denegación de servicio (DoS/DDoS) e Ingeniería Social (Phishing).

3. AUTORIZACIÓN Y CONDICIONES

Explica qué permisos y condiciones deben estar definidos antes de comenzar.

PERMISOS REQUERIDOS

- **Carta de Autorización Formal:** Documento firmado por la gerencia (Rules of Engagement).
- **Acuerdo de Confidencialidad (NDA):** Protección legal para la información descubierta.
- **Cuentas de Prueba:** Credenciales asignadas para pruebas con diferentes niveles de rol (cliente / admin).

CONDICIONES ACORDADAS

- **Ventana Horaria:** Pruebas ejecutadas exclusivamente en horarios de menor actividad operativa.
- **Integridad de Datos:** Prohibición estricta de alterar o destruir datos reales de clientes.
- **Notificación Inmediata:** Detener pruebas y avisar si se halla un riesgo crítico que amenace la estabilidad.

4. TIPO DE PENTEST

Determina el tipo y justifica la elección.

TIPO ELEGIDO: GRAY-BOX (Caja Gris)

BLACK-BOX

Sin conocimiento previo.

GRAY-BOX ✓

Información parcial (credenciales/rutas).

WHITE-BOX

Acceso total a código e infra.

JUSTIFICACIÓN DE LA ELECCIÓN

Se elige **Gray-Box** porque Aurora Market proporciona información parcial sobre los componentes existentes (aplicación web, base de datos, panel interno y roles de usuarios) sin entregar acceso al código fuente.

Esto simula de manera realista el escenario del problema reportado: la perspectiva de un atacante con cuenta de usuario o conocimiento limitado del sistema.

5. PLANIFICACIÓN

Elementos clave antes de iniciar la parte técnica.

🎯 **OBJETIVOS:** Identificar vulnerabilidades de control de acceso y fallas web en Aurora Market.

📋 **ALCANCE:** Aplicación e-commerce pública y módulo web de administración interna.

🔒 **PERMISOS Y CONDICIONES:** RoE firmado, trabajo fuera de horas pico, sin interrupción de servicio.

🛠️ **METODOLOGÍA A UTILIZAR:** OWASP WSTG v4.2 / PTES.

🔍 **RECOPIACIÓN PREVIA:** Mapeo de endpoints, puertos web y tecnologías expuestas.

💻 **RECURSOS NECESARIOS:** Burp Suite, Nmap, OWASP ZAP, cuentas de prueba y canales seguros.

📅 **PROGRAMACIÓN:** Ejecución de pruebas durante 5 días hábiles en ventana nocturna.

6. FASES DEL PENTEST

Aplicación del flujo técnico al caso.

1. RECONOCIMIENTO:

Descubrimiento de endpoints, parámetros de la URL y tecnologías del servidor.

2. ANÁLISIS DE VULNERABILIDADES:

Auditoría de autenticación, sesiones, autorización (IDOR) e inyecciones.

3. EXPLOTACIÓN:

Verificación segura de vulnerabilidades sin comprometer la base de datos real.

4. POST-EXPLOTACIÓN:

Determinación del nivel de impacto y alcance potencial del acceso indebido.

5. INFORME:

Documentación técnica y ejecutiva con plan detallado de remediación.

7. INVESTIGACIÓN

Consulta de metodología de evaluación

METODOLOGÍA ELEGIDA:

OWASP WSTG (Web Security Testing Guide v4.2)

¿POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?

Es el estándar de la industria específico para auditorías web. Ofrece un marco metodológico estructurado para probar exhaustivamente los controles de autenticación, gestión de sesiones y control de acceso a datos, permitiendo resolver con precisión el incidente de fuga de datos en Aurora Market.